Objective 2.1 — Apply information gathering techniques

Everything in 2.1 sorts onto one axis: **passive vs active** — decided solely by whether traffic touches the target's own systems. Color encodes that split throughout (passive / active / either). Domain 2.0 is 21% of the exam — the second-heaviest.

1 · Passive / active map

Passive
no packets to target - undetectable

■ Social media OSINT ■ Job boards ■ Scan code repositories ■ Cached pages ■ Cryptographic flaws ■ Password dumps ■ Certificate transparency logs ■ Search engine analysis

Active
direct probes - detectable

■ TCP scanning ■ UDP scanning ■ Banner grabbing

Either / nuanced
passive via 3rd-party, active on target

■ DNS lookups + zone transfer ■ Reverse DNS lookups ■ Network reconnaissance ■ Information disclosure ■ Network sniffing ■ IoT / OT protocols ■ HTML scraping

Characteristic	Passive	Active
Direct target interaction	No	Yes
Detection risk	Low	Higher
Data accuracy	Lower (may be outdated)	Higher (current)
Authorization sensitivity	Lower	Higher
Data source	Third parties, public records	Target systems directly
Example tools	Maltego, Shodan, WHOIS	Nmap, Netcat, dig (vs target)

Exam tell: "without interacting / publicly available / third-party / stealthy" -> passive; "scans / sends packets / connects to service / logged by target" -> active.

2 · Concept cards

Each 2.1 technique in one card: what it is, high-yield facts, tools, exam tell. Cover it and recite the tell first.

PASSIVE TECHNIQUES

Social media OSINT PASSIVE

2.1 > OSINT > Social media

WHAT IT IS Aggregating employee/exec posts to map the org and its technology.

- **LinkedIn** = org chart + tech stack + certs of IT/security staff
- Photos leak badges, whiteboards, screens (**media leakage**)
- Feeds **pretexting** for convincing social engineering

TOOLS LinkedIn, Twitter/X, Maltego, theHarvester
EXAM TELL "LinkedIn reveals security tools" / "badge in event photo" -> social media OSINT (passive).

Job boards PASSIVE

2.1 > OSINT > Job boards

WHAT IT IS Postings disclose the exact tech, vendors, and versions in use.

- Reveals **SIEM/EDR/firewall brands**, cloud providers, frameworks, compliance scope
- "migrating from X to Y" = **transitional risk** (gaps during migration)
- All before a single packet is sent

TOOLS Careers page, Indeed, LinkedIn Jobs
EXAM TELL "posting lists FortiGate + Splunk ES" -> job-board OSINT; "migration experience" -> transitional risk.

Scan code repositories PASSIVE

2.1 > OSINT > Code repos

WHAT IT IS Public Git repos leak secrets and infrastructure detail.

- Hardcoded creds, API keys, .env files, internal hostnames
- Secrets **persist in commit history** even after "removal"
- Scan with TruffleHog / GitLeaks

TOOLS `GitHub, GitLab, TruffleHog, GitLeaks`
EXAM TELL "API key in commit history" -> code-repo OSINT; persistence-in-history is a favorite distractor.

Cached pages PASSIVE

2.1 > OSINT > Cached pages

WHAT IT IS Historical snapshots preserve content since removed from the live site.

- **Wayback Machine** = longitudinal history across years
- Recover removed admin portals, deleted docs, old versions
- Proves digital info persists after deletion

TOOLS `Wayback Machine, Google Cache, Bing Cache`
EXAM TELL "Wayback Machine reveals old admin portal" -> cached pages (passive).

Cryptographic flaws PASSIVE

2.1 > OSINT > Crypto flaws

WHAT IT IS Public cert/TLS inspection flags weak crypto without touching the server.

- Weak: **SSLv2/3, TLS 1.0/1.1, RC4/3DES/DES, MD5/SHA-1**
- **SAN field** = subdomain goldmine; expired cert = poor hygiene
- Identified via Shodan / Censys / SSL Labs (passive)

TOOLS `Shodan, Censys, SSL Labs, nmap ssl-cert`
EXAM TELL "server supports TLS 1.0" -> crypto flaw; "SAN reveals subdomains" -> cert metadata as OSINT.

Password dumps PASSIVE

2.1 > OSINT > Password dumps

WHAT IT IS Breach data reveals corporate emails and password patterns.

- Confirms email format; exposes reuse patterns (Company2023!)
- Feeds spraying / credential stuffing / dictionary attacks
- **rockyou.txt** is derived from real breach data

TOOLS `Have I Been Pwned, breach repos, rockyou.txt`
EXAM TELL "HIBP domain search" / "rockyou.txt" -> password dumps.

Certificate transparency logs PASSIVE

2.1 > Certificate transparency logs

WHAT IT IS Public append-only logs of every issued cert -> passive subdomain enum.

- **SAN fields** list every hostname -> dev/staging/internal + forgotten assets
- Permanent record - entries can't be deleted
- Let's Encrypt bursts = CI/CD; detects rogue/misissued certs

TOOLS `crt.sh, Censys`
EXAM TELL "subdomain found without scanning" / "crt.sh %.domain" -> CT logs (passive).

Search engine analysis PASSIVE

2.1 > Search engine analysis

WHAT IT IS Advanced operators surface content the org never meant to expose (Google dorking).

- site:, filetype:, intitle:, inurl:, intext:, cache:
- Finds login portals, exposed docs, SQL dumps, error pages
- **GHDB** = curated dork library (Exploit-DB); purely passive

TOOLS `Google, GHDB`
EXAM TELL "site: filetype:sql" -> dorking; 'intitle:"index of"' -> open directory listing.

ACTIVE TECHNIQUES

TCP scanning ACTIVE

2.1 > Protocol scanning > TCP

WHAT IT IS Probing TCP ports via handshake behavior to find open services.

- **-sS** SYN/half-open = stealth, **needs root**, most common
- **-sT** connect = full handshake, **no root**, more logged
- **-sF/-sN/-sX** bypass simple filters but unreliable on **Windows** (RST all)
- **-sA** maps firewall rules; states: open / closed / filtered

TOOLS `Nmap -sS / -sT / -sF / -sN / -sX / -sA`
EXAM TELL "half-open" -> -sS; "no root available" -> -sT; "maps firewall rules" -> -sA.

UDP scanning ACTIVE

2.1 > Protocol scanning > UDP

WHAT IT IS Connectionless scanning - slow and ambiguous.

- Closed -> **ICMP Port Unreachable**; open -> reply or silence
- No reply = **open|filtered** (can't disambiguate)
- Rate-limited/slow; needs root
- Key UDP: 53 DNS, 67/68 DHCP, 69 TFTP, **161 SNMP**, 123 NTP, 500 IKE

TOOLS `Nmap -sU`
EXAM TELL "ICMP Port Unreachable" -> UDP closed; "open|filtered" -> UDP ambiguity; SNMP/161 high-value.

Banner grabbing ACTIVE

2.1 > Banner grabbing

WHAT IT IS Connect to a service and read its banner to get software + version.

- **Always active** - requires a direct connection
- Version -> CVE / Exploit-DB / Metasploit / EOL check
- nc/telnet manual; curl -I; wget -S; nmap -sV
- Hardened services can suppress/falsify banners

TOOLS `Netcat, curl -I, wget -S, Nmap -sV`
EXAM TELL "nc to :22 shows OpenSSH version" / "curl -I Server: Apache" -> banner grabbing (active).

EITHER / NUANCED

DNS lookups + zone transfer EITHER

2.1 > OSINT > DNS > lookups

WHAT IT IS Forward lookups resolve names to IPs and expose infra via record types.

- **A/AAAA**=IPs, **MX**=mail provider, **NS**=DNS host, **TXT**=SPF/DKIM/DMARC, **SRV**=hidden services
- **AXFR zone transfer**: whole zone dumped if server allows transfers from any source (critical misconfig)
- Blocked AXFR -> brute subdomains with dnsrecon / Amass

TOOLS `dig, nslookup, host, dnsrecon, Amass, DNSdumpster`
EXAM TELL "zone transfer reveals all records" -> AXFR. 3rd-party DNS DB = passive; dig against target NS = active.

Reverse DNS lookups EITHER

2.1 > OSINT > DNS > reverse

WHAT IT IS PTR query resolves an IP back to a hostname.

- dig -x <IP> confirms ownership + reveals naming conventions
- Sweeping a CIDR expands the attack surface
- Not every IP has a PTR (absence != unused)

TOOLS `dig -x, nslookup`
EXAM TELL "dig -x returns web01.company.com" -> reverse DNS / PTR.

Network reconnaissance EITHER

2.1 > Network reconnaissance

WHAT IT IS Mapping IP ranges, routing, and hosts - external footprint to internal map.

- **WHOIS / ARIN / RIPE** = CIDR ranges (passive); **ASN** -> all org IP ranges
- **traceroute** = path, reveals CDN / cloud front (active)
- Internal (post-access): ARP / ICMP / TCP host discovery

TOOLS `WHOIS, ARIN, traceroute, Nmap, Shodan, BGP toolkits`
EXAM TELL "ARIN lookup reveals IP range" -> network recon; CIDR notation defines scope.

Information disclosure EITHER

2.1 > Information disclosure

WHAT IT IS Unintentional exposure of sensitive data via misconfig or oversight.

- Open dir listings; /server-status, /phpinfo.php, /actuator
- Stray backups (.bak, db.sql); debug mode; verbose stack traces
- Public **S3 / Blob / GCS** buckets
- Each disclosure is a **stepping stone**, not the goal

TOOLS `Shodan, Censys, browser, cloud-enum tools`
EXAM TELL "phpinfo.php exposed" / "public S3 bucket" / "stack trace reveals paths" -> info disclosure (chains into next attack).

Network sniffing EITHER

2.1 > Network sniffing

WHAT IT IS Capturing traffic to read credentials, tokens, and topology.

- NIC **promiscuous mode**; **PCAP** = capture format
- **Wireshark** (GUI, Follow TCP Stream) vs **tcpdump** (CLI, BPF filters)
- Cleartext: **Telnet, FTP, HTTP, LDAP, SNMPv1/2c**
- Captures NTLM hashes, Kerberos tickets, session cookies; passive listen vs active w/ ARP poisoning

TOOLS `Wireshark, tcpdump`
EXAM TELL "cleartext creds captured" / "Follow TCP Stream" / "PCAP" -> sniffing; "BPF filter" -> tcpdump.

IoT / OT protocols EITHER

2.1 > Network sniffing > IoT/OT

WHAT IT IS Industrial/IoT protocols built for reliability, not security.

- **MQTT** pub/sub - TCP 1883 (plain) / 8883 (TLS), often no auth
- **Modbus** TCP 502 - no auth, no encryption
- DNP3 (utilities), BACnet (buildings), CAN bus (automotive)
- OT is fragile -> prefer **passive port mirroring / tap**

TOOLS `Wireshark dissectors, Scapy`
EXAM TELL "Modbus TCP 502" / "MQTT broker no auth" -> OT/IoT; "port mirroring in ICS" -> passive OT monitoring.

HTML scraping EITHER

2.1 > HTML scraping

WHAT IT IS Extracting intel from page source and HTTP headers.

- Reveals CMS (meta generator), JS frameworks, versions, dev comments, hidden fields/tokens
- Active (server logs it) vs passive (cached / Wayback)
- **robots.txt is NOT an access control** - it maps sensitive dirs to browse
- sitemap.xml = full URL map; missing security headers is itself a finding

TOOLS `curl, wget, Scrapy, Beautiful Soup, Burp, DevTools`
EXAM TELL "robots.txt Disallow /admin" -> not access control, browse it; "meta generator = WordPress" -> CMS ID.

3 · Keyword → concept reference

The fastest scenario-recognition drill: cover the right column and name the concept from the stem phrase.

KEYWORD / PHRASE	MAPS TO
`No direct interaction with target`	Passive reconnaissance
`Sends packets to target`	Active reconnaissance

KEYWORD / PHRASE	MAPS TO
Shodan / Censys query	Passive recon (platform scanned, not you)
WHOIS lookup	Passive recon / network recon
Nmap scan	Active recon
Banner grabbing	Active recon (always)
OSINT	Passive recon / info gathering
LinkedIn org chart	Social media OSINT
Job posting reveals firewall brand	Job board OSINT
API key in GitHub	Code-repo OSINT / info disclosure
Zone transfer (AXFR)	DNS misconfig / DNS enumeration
PTR record / dig -x	Reverse DNS lookup
SAN field in certificate	CT logs / certificate metadata
crt.sh	Certificate transparency log search
Wayback Machine	Cached pages / passive recon
TLS 1.0 / RC4 / SHA-1	Cryptographic flaw
OCSP / CRL	Certificate revocation
Have I Been Pwned	Password dumps
rockyou.txt	Password dump / dictionary wordlist
ARIN / RIPE / APNIC	Network recon / IP range ID
CIDR notation	Network scope / IP range
traceroute	Network path analysis
SYN scan / half-open	TCP scanning (-sS), needs root
Connect scan	TCP scanning (-sT), no root
FIN / NULL / Xmas scan	TCP filter bypass; fails on Windows
ACK scan	Maps firewall rules (-sA)
UDP scan	UDP scanning (-sU)
ICMP Port Unreachable	UDP closed-port response
open|filtered	UDP ambiguous port state
-sn	Nmap host discovery (ping scan)
-Pn	Treat all hosts as alive (skip discovery)
-sV	Service version detection
-O	OS fingerprinting
Open directory listing	Info disclosure / server misconfig
Public S3 bucket	Cloud misconfig / info disclosure
Stack trace in error message	Verbose error / info disclosure
phpinfo.php / /server-status	Information disclosure
site: filetype: intitle: inurl:	Google dorking / search engine analysis
GHDB	Google Hacking Database
Wireshark / tcpdump	Network sniffing
PCAP file	Packet capture / network sniffing
Follow TCP Stream	Wireshark session reconstruction
Cleartext credentials	Sniffing - Telnet/FTP/HTTP/LDAP

KEYWORD / PHRASE	MAPS TO
MQTT / Modbus	IoT / OT protocols
Modbus TCP 502	OT / ICS protocol
Port mirroring in ICS	Passive OT monitoring
BPF filter	tcpdump filter syntax
curl -I / wget -S	Banner grabbing / header retrieval
Netcat to a port	Banner grabbing / manual probe
robots.txt	NOT an access control - maps sensitive paths
sitemap.xml	Full application URL map
HTML comment with credentials	Info disclosure via HTML scraping
Meta generator tag	CMS identification / HTML scraping
Scrapy / Beautiful Soup	HTML scraping tools

4 · Recognition quiz (answer key included)

Scenario in, identification out - the exam's format for 2.1. Call it (passive/active + technique + tool), then check.

Q01

```
A tester queries Shodan for the target's internet-exposed devices and cipher support.
```

Passive or active? Why?

Passive - Shodan/Censys OSINT PASSIVE

WHAT'S HAPPENING The tester reads data Shodan already collected; no packets go to the target.

WHY The classic trap: the **platform** did the scanning. The tester's query is passive - it never touches the target directly.

Q02

```
nc -v 10.0.0.5 22 returns SSH-2.0-OpenSSH_7.2p2 Ubuntu
```

Technique and classification?

Banner grabbing - active ACTIVE

WHAT'S HAPPENING A raw connection reads the service banner, revealing OpenSSH 7.2 and the OS.

WHY Banner grabbing is **always active** - it opens a connection. Version -> CVE lookup is the follow-on.

Q03

```
A job posting requires experience with "Fortinet FortiGate" and "Splunk ES."
```

What OSINT source, and what did it reveal?

Job-board OSINT PASSIVE

WHAT'S HAPPENING The posting discloses the firewall and SIEM in use before any contact with the target.

WHY Job boards leak the tech stack; a stated migration would additionally signal **transitional risk**.

Q04

```
A DNS server accepts an AXFR request from any host and returns every record.
```

What is this and why does it matter?

Zone transfer (AXFR) misconfiguration EITHER

WHAT'S HAPPENING A single query dumps the entire DNS zone - all hostnames, IPs, and record types.

WHY It should be restricted to authorized secondaries. Open AXFR is a critical, frequently-tested misconfig.

Q05

```
nmap -sU -p161 target gets no response from port 161.
```

Port state and likely service?

UDP open|filtered - SNMP ACTIVE

WHAT'S HAPPENING No reply on a UDP scan means **open|filtered** - can't tell open from firewalled.
WHY Closed UDP would return ICMP Port Unreachable. Silence is ambiguous; 161 is SNMP, a high-value UDP target.

Q06

```
A tester needs to scan TCP but has no root/administrator privileges.
```

Which scan type?

TCP connect scan (-sT) ACTIVE

WHAT'S HAPPENING The connect scan uses the OS socket API, so it needs no elevated privileges.
WHY -sS (SYN/half-open) requires root for raw packets. -sT completes the handshake and is more likely logged.

Q07

```
Querying crt.sh for %.company.com returns dev.company.com and vpn.company.com.
```

Technique and classification?

Certificate transparency logs - passive PASSIVE

WHAT'S HAPPENING SAN fields in logged certs expose subdomains, including dev/staging, without scanning.
WHY CT logs are permanent and public - subdomain discovery "without touching the target."

Q08

```
dig -x 203.0.113.20 returns db-prod.company.com.
```

What kind of lookup?

Reverse DNS (PTR) lookup EITHER

WHAT'S HAPPENING Resolving an IP back to a hostname; the name also leaks a naming convention.
WHY -x is the reverse-lookup flag. Sweeping the CIDR would reveal more of the same scheme.

Q09

```
robots.txt on the target contains Disallow: /admin-portal/
```

What should the tester conclude?

robots.txt is not an access control EITHER

WHAT'S HAPPENING The Disallow entry is a hint to crawlers, not a restriction - browse the path directly.
WHY robots.txt effectively hands you a **map of sensitive directories** the org tried to hide from search engines.

Q10

```
curl -I https://target shows Server: Apache/2.4.29
```

Technique, classification, next step?

Banner grabbing / header analysis - active ACTIVE

WHAT'S HAPPENING The HEAD request returns headers disclosing the exact web-server version.
WHY A direct request = active. Version -> search NVD/Exploit-DB for CVEs affecting 2.4.29.

Q11

```
A FIN scan against a Windows host returns RST for every port.
```

What limitation does this show?

FIN/NULL/Xmas unreliable on Windows ACTIVE

WHAT'S HAPPENING Windows replies RST regardless of port state, so these scans can't distinguish open ports.
WHY FIN/NULL/Xmas rely on RFC-compliant "open ignores" behavior - useful for filter bypass on *nix, not Windows.

Q12

```
Captured traffic shows Modbus commands on TCP port 502 in cleartext.
```

What environment and concern?

OT / ICS protocol (Modbus) EITHER

WHAT'S HAPPENING Modbus TCP has no authentication or encryption; any host on the segment can issue commands.
WHY OT is fragile - prefer passive port mirroring over active probing to avoid disrupting the process.

Q13

```
site:company.com filetype:sql surfaces an exposed database dump.
```

Technique and classification?

Search engine analysis (Google dorking) PASSIVE

WHAT'S HAPPENING Operators narrow the index to files the org never meant to publish.
WHY Purely passive - no target interaction. The GHDB catalogs queries like this.

Q14

```
TruffleHog flags an AWS key inside an old commit that was "deleted" from the current
file.
```

Why is the key still exposed?

Secrets persist in Git history PASSIVE

WHAT'S HAPPENING Removing a secret from the latest file leaves it intact in prior commits.
WHY Commit history is the real exposure surface - a favorite exam nuance for code-repo OSINT.